

BY: MAJORKALI

The IoT Paradox

Ambient Hostility in the Age of Connectivity



The 2025 IoT Paradox

🔗 Total IoT Base: 18–19 Billion Devices

Projected 40B+ by 2030 – representing a **2.1x expansion** in just five years. This exponential growth creates an unprecedented attack surface.

Each device becomes a potential foothold for adversaries, from smart thermostats to industrial controllers.

💀 Industrialization of Risk

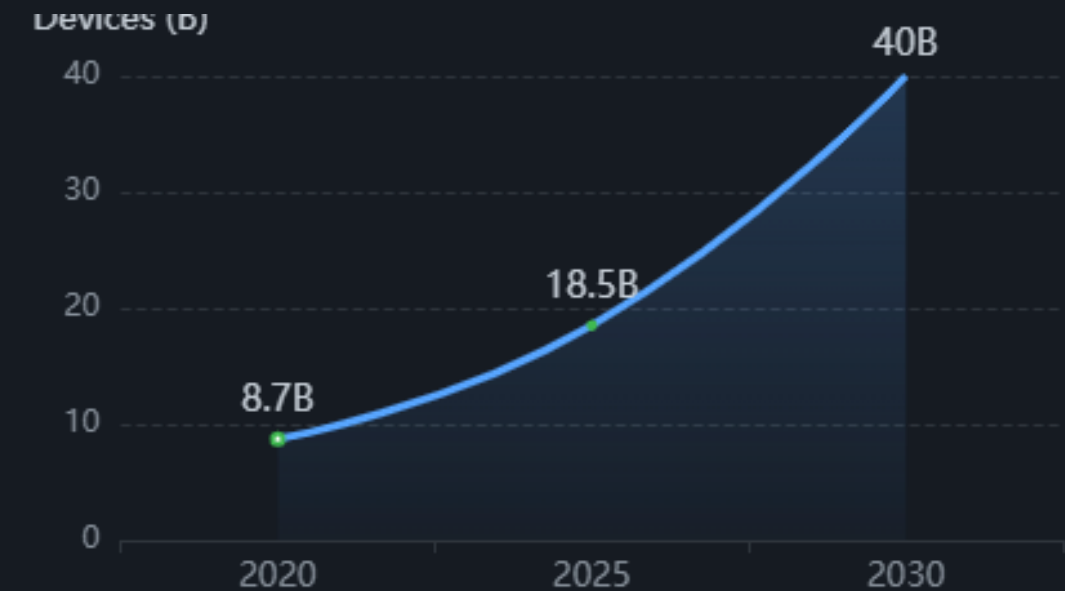
Botnets evolved from "script kiddie" tools into **multi-tiered enterprises** with state backing and monetization.

Core Shift: Moving beyond simple "zombie" PCs to **persistent, high-capacity IoT nodes** for systemic infrastructure disruption.

💡 The Paradox

Connectivity expands, but each connection increases fragility. The same devices enabling digital transformation become weapons.

IoT Device Growth Trajectory



18-19B

Current IoT Base
2025

40B+

Projected Base
2030

Attack Surface Expansion

- Consumer Smart Devices
- Industrial IoT Controllers
- Medical & Critical Infrastructure

Constant Probing & Volumetric Surges



The Era of "Ambient Hostility"

Port Scan Dominance

93%

of all network intercepts are port scans, creating a constant background noise of reconnaissance.



Daily Hacking Attempts

820K

attacks per day on IoT devices, a **46% YoY increase**.



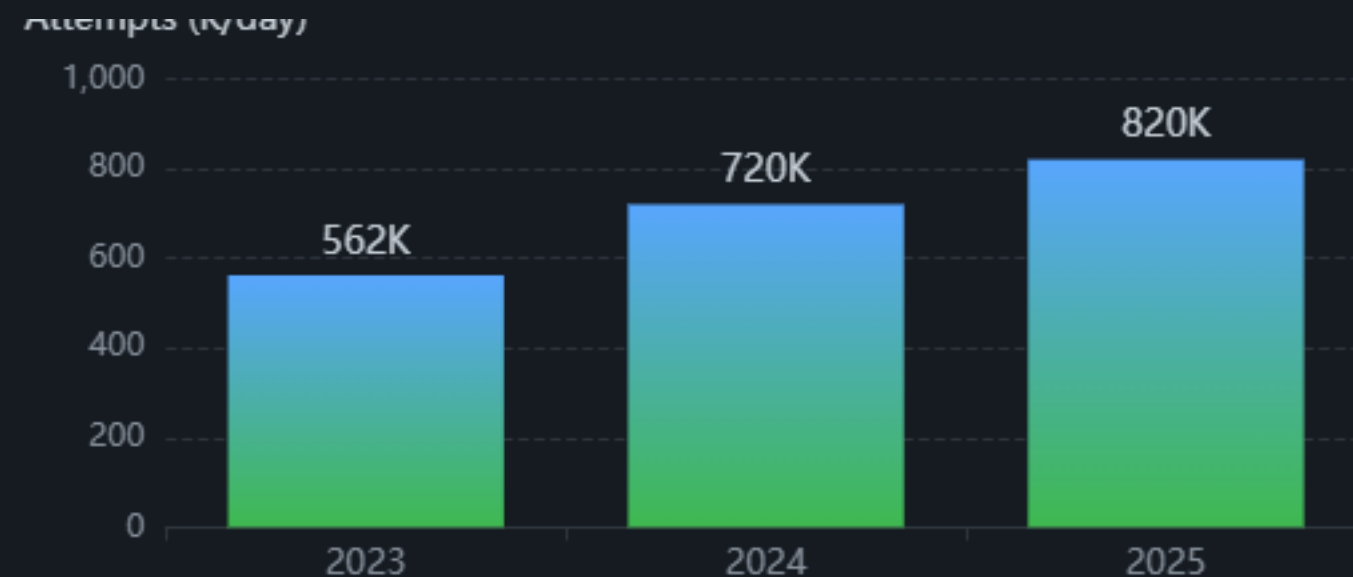
CVE Database

305K+

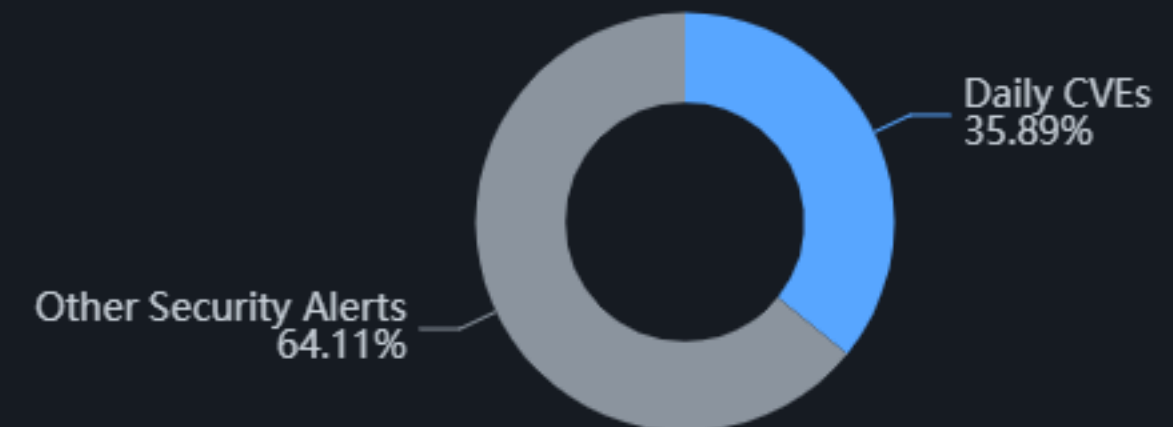
records with **131 daily disclosures** in 2025.



Attack Attempt Growth (YoY)



Daily CVE Disclosures (2025)



Ambient Hostility Defined

The new normal: a constant, automated assault on network infrastructure. No device is too obscure to escape attention, with attacks emerging from every vector.



LLMs Lowering the Barrier to Entry

The AI-Assisted Breach

Exploitation Surge (Late 2024 - Early 2025)



The AI Factor

Threat actors leverage **Large Language Models (LLMs)** to automate vulnerability discovery, lowering the barrier to entry.



Firmware Analysis

LLMs reverse-engineer firmware at machine speed.



Script Generation

AI generates weaponized code for identified flaws.



Malware-Free Future

79% of detections are now "malware-free," as attackers use legitimate tools and "hands-on-keyboard" techniques.



Living off the Land



Stolen Credentials



Interactive Intrusion

+124%

Vulnerability-Based Attacks

Late 2024 - Early 2025

79%

Malware-Free Detections

"Hands-on-keyboard" techniques



From Source Code to Fragmented Families

Evolution of the Mirai Legacy



The Blueprint

Mirai-derived components found in **72%** of all new IoT malware

72%

Mirai Derivatives



Mozi

Architecture

Decentralized, P2P-based network eliminating single points of failure.

Innovation

Distributed hash tables (DHT) for C2 infrastructure, resilient to takedowns.



Reaper

Speed Focus

Faster infection cycles by targeting specific manufacturer flaws.

Tactical Shift

Quality over quantity: fewer, higher-value nodes for more effective attacks.



OMG

Specialization

Transforms IoT devices into anonymous proxies for traffic routing.

Monetization

Pioneered the proxy service model, turning botnets into revenue streams.



The 30-Terabit DDoS Era

Case Study: The Aisuru Botnet



World-Record Attacks

Peak DDoS Capacity

29.7

Tbps
Bandwidth

14.1B

Bpps
Packet Rate

Aisuru orchestrated attacks **1000x larger** than most countries' internet capacity.



Rapid Scaling

Aisuru grew to **over 300,000 nodes** by breaching a **Totolink firmware update server** in April 2025.

Infection Strategy

- Compromised firmware update mechanism
- Injected payload into legitimate updates
- Achieved persistence across reboots
- Automated propagation to peer devices



Sophistication



Modified RC4

Custom encryption



Anti-Sandbox

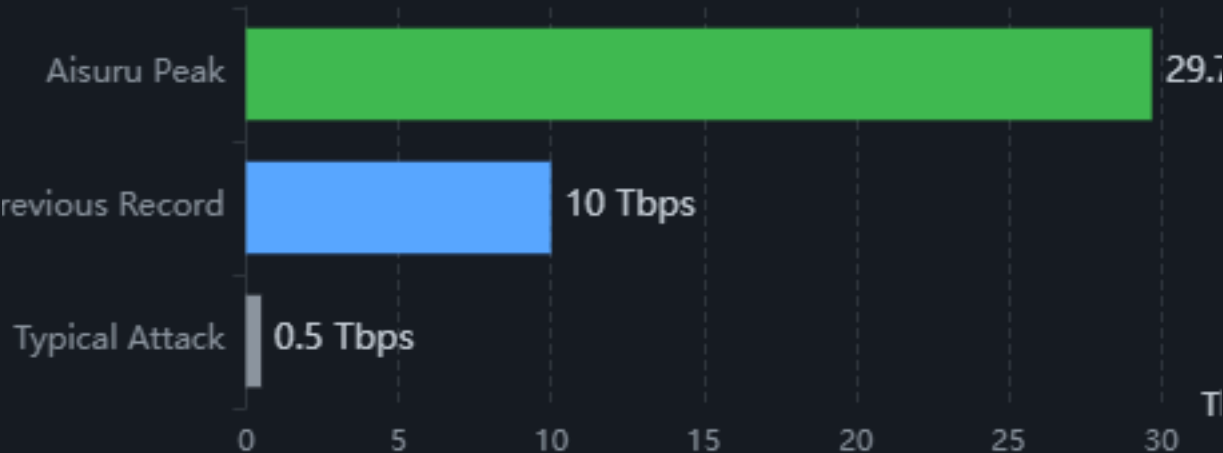
Detects analysis



GRE Tunnels

Masks C2 traffic

Attack Capacity Comparison





Multi-Tiered C2 Architecture (Flax Typhoon)

The "Raptor Train" Infrastructure

Tier 1

Nodes

Compromised Devices: SOHO routers and NAS servers, the workhorses of the botnet.

Avg. Lifespan

17.4

Days

Tier 2

Control

Infrastructure: Exploitation and payload servers, the logistical backbone.

Rotation Cycle

75

Days

Tier 3

Management

Centralized: "Sparrow" (NCCT) Electron application for state-sponsored operations.

Operations

State-Level

Sparrow App

Tier Lifespan Comparison



FBI Takedown

Operation Scale

1.2M+

Compromised Device Records

Exposed in a single operation.



New Monetization: Residential Proxies



The Business Model

Botmasters **rent infected IoT devices** to proxy services for "stealth" traffic.

Revenue Flow

1. Botmaster controls infected devices
2. Proxy service "rents" device access
3. Customers route traffic for various purposes
4. Profit shared across the ecosystem

Global Capacity

100-200M

IPv4 Endpoints

Covertly retransmitting traffic, masking true origins.

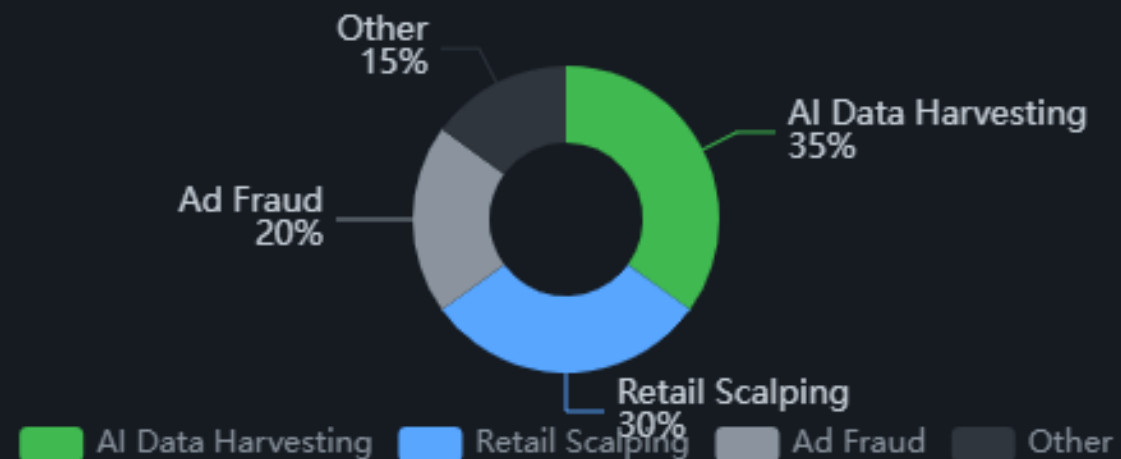
The AI Connection

Proxies are increasingly used for **AI-driven data harvesting** and retail "scalping."

95%

Black Friday Footwear Checkouts
Were Bots

Proxy Utilization by Use Case



Why IoT Proxies Are Valuable



Reputation

Residential IPs have high reputation scores, bypassing geo-blocks.



Rotation

Millions of IPs enable sophisticated rotation strategies.



Anonymity

Traffic appears to originate from legitimate residential connections.



Profit

Botmasters monetize infections without launching attacks.



The Convergence of IoT and OT

Supply Chain Fragility & Kinetic Risk



Supply Chain Poisoning

The BadBox 2.0 Incident

Infected **10 million devices** via pre-installed firmware on TVs and projectors.

Malware was introduced **at the factory**, infecting devices before purchase.



Industrial Impact

+459% Vulnerability-Based Attacks vs. Manufacturing

Manufacturing sectors face a surge in attacks as compromised IoT devices become entry points.



The Danger

Compromised IoT devices serve as **"pivots"** into critical infrastructure.

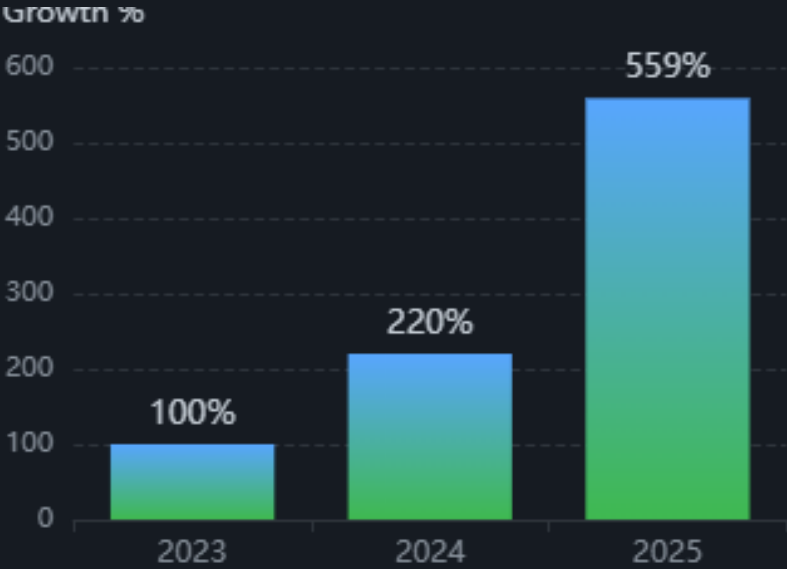
Water Treatment Plants

IoT sensors pivot to OT networks controlling chemical dosing.

Medical IoMT Devices

Compromised infusion pumps and imaging systems enable lateral movement.

Attack Surge vs. Manufacturing



Kinetic Risk

The line between digital and physical is gone. IoT compromise can have real-world consequences.



Shifting from Compliance to Enforcement

Regulatory Response: India's 2025 Mandate



CERT-In Guidelines

Mandatory annual **3rd-party audits** for all public and private enterprises.

Scope

All enterprises: public, private, and government.

Frequency

Annual comprehensive security assessments.



The 6-Hour Rule

Organizations must report **ransomware or DDoS attacks** within 6 hours of detection.

Reporting Requirements

- Immediate notification to CERT-In
- Detailed incident analysis within 24 hours



Expanded Bill of Materials



HBOM

Hardware Bill of Materials



AIBOM

AI Behavior & Training Data

Regulatory Timeline

Detection

0 Hours

Attack identified

Reporting

6 Hours

Mandatory notification

Analysis

24 Hours

Detailed report

Compliance Pillars



Annual 3rd-Party Audits



6-Hour Incident Reporting



Enhanced BOM Requirements



NIST SP 1800-36 Pillars

The Zero Trust Blueprint for IoT

Pillar 1



Trusted Onboarding

Establish trust before a device joins a network. Every device must prove its identity and integrity.

Implementation

- Cryptographic attestation
- Firmware verification
- Manufacturer signature validation

Pillar 2



Identity-Centric Security

Replace shared passwords with unique, cryptographically verifiable identities.

Implementation

- Public key infrastructure (PKI)
- Device certificates
- Mutual TLS authentication

Pillar 3



Behavioral Monitoring

Use Manufacturer Usage Descriptions (MUD) to monitor and revoke access if a device deviates.

Implementation

- MUD file validation
- Continuous behavior analysis
- Automated access revocation



Zero Trust Principle

"Never Trust, Always Verify"

No implicit trust is granted based on network location. Every device must continuously prove its identity and intent. This shifts security from perimeter-based to **identity-centric**.

CONCLUSION

The Path Forward

In an era of **ambient hostility**, proactive defense isn't optional—it's **existential**.

The question isn't whether IoT devices will be compromised, but whether we can **architect resilience** faster than adversaries weaponize connectivity.



18 Billion Devices

Each a potential soldier in an invisible army



Zero Trust

The only viable defense strategy



AI vs. AI

An arms race for the future



The battlefield is everywhere. The war is now.

THANK YOU

REGARDS @MAJORKALI

Follow us on:



<https://www.linkedin.com/company/cidint/>



<https://t.me/CIDINT>